

NODE.JS LOCALAPPDATA LOADER

Defender XDR hunt for the source-observed WScript bootstrap launching portable Node.js from a user-writable directory without a JavaScript file on the child command line.

HUNTING QUERY

CONFIDENCE: MEDIUM

wscript.exe

JScript bootstrap under LocalAppData



node.exe

portable signed runtime

HUNT • COLLECT • CONTAIN

validate legitimate developer tooling

REPORT DATE

7 September 2026

STATUS

Untested implementation sketch

PRIMARY TELEMETRY

Defender XDR /
DeviceProcessEvents

OPERATIONAL VALUE

9.5 / 10

Campaign-specific execution hunt. A match does not prove Teams contact, implant decryption, persistence or C2.

CONTROLLED EIGHT-PAGE THREAT DOSSIER



EXECUTIVE ASSESSMENT

Decision-grade summary and strict evidence boundary.

ASSESSMENT

OPERATIONAL VALUE

9.5

Direct process telemetry captures a distinctive source-observed bridge from Windows Script Host to a portable Node.js runtime under LocalAppData.

CLASSIFICATION

Campaign-specific execution

Hunting query - Untested implementation sketch. Legitimate Node.js packaging and endpoint-management workflows require local validation.

1primary event

4direct filters

0thresholds

0joins

Source fact

Microsoft observed WScript launching portable Node.js from LocalAppData to execute a staged implant through standard input or nonstandard-extension material.

Vendor interpretation

The signed runtime and unconventional loader path help the chain blend with legitimate software and evade extension-focused controls.

Assumptions

Defender for Endpoint retains full child and initiating command lines and the observed image names.

Evidence boundary

The event does not prove external Teams contact, remote control, MSI delivery, implant decryption, persistence, C2, discovery or lateral movement.



THREAT MECHANICS

Observed campaign chain and selected detection point.

BEHAVIOR

01 External Teams contact

An actor impersonated IT or helpdesk staff from another tenant.
→

02 Remote session

The user granted interactive control through remote-support tooling.
→

03 Silent MSI

PowerShell downloaded a cloud-hosted MSI installed with suppressed UI.

04 Portable runtime

The MSI placed Node.js and encrypted implant material under LocalAppData.
→

05 WScript bridge

A JScript wrapper launched Node.js against staged input.
→

06 Operator tasking

The implant supported HTTPS polling, discovery, screen capture and WinRM pivots.

Evidence point	Direct observation
Publication	Microsoft Security Research, 2 September 2026.
Campaign period	Active campaign; exact start and end dates were not disclosed.
Selected signal	WScript parent, Node.js child, LocalAppData command lines, and child command line without .js.
Known drift	Renamed Node.js copies and standard-input or temporary JavaScript execution were observed.

ATT&CK
T1059.007 JavaScript/JScript and T1036 Masquerading directly support the selected execution point.



TELEMETRY & EVIDENCE MODEL

Minimum data contract and observability gaps.

TELEMETRY

REQUIRED

DeviceProcessEvents

Microsoft Defender for Endpoint process creation with created process, command line, version metadata and initiating process.

OPTIONAL ENRICHMENT

DeviceFileEvents, DeviceRegistryEvents, DeviceNetworkEvents, DeviceFileCertificateInfo, Teams evidence, MSI logs and approved Node.js inventory.

Field	Reliability	Purpose
Timestamp, DeviceId, DeviceName	Documented	Scope and pivots
FileName, FolderPath	Documented	Node child and user-writable path
ProcessCommandLine	Documented	LocalAppData and no .js token
ProcessVersionInfoOriginalFileName	Documented	Investigate renamed Node.js copies
InitiatingProcessFileName	Documented	WScript parent
InitiatingProcessCommandLine	Documented	Wrapper path and arguments
ReportId	Documented	Use with DeviceName and Timestamp

Unavailable through this event

Teams sender identity, user consent, remote-control session, MSI provenance, encrypted file content, decrypted JavaScript, successful C2 or later operator actions.

Coverage failure

No Defender for Endpoint, missing command lines, renamed WScript, path variation outside LocalAppData, .js on the child command line, or activity outside retention.



HUNTING LOGIC

Four direct source-supplied conditions; no threshold or join.

KQL

HYPOTHESIS

If an attacker executes the observed staged Node.js implant, endpoint telemetry should show wscript.exe launching node.exe from LocalAppData while the child command line omits a .js file. The behavior can be distinguished through approved developer-tool inventory, package context, signer and file provenance, parent script collection, MSI evidence and user support activity.

KQL - UNTESTED HUNT

```
DeviceProcessEvents
| where FileName =~ "node.exe"
| where ProcessCommandLine has @"\AppData\Local\"
  and ProcessCommandLine !contains ".js"
| where InitiatingProcessFileName =~ "wscript.exe"
| where InitiatingProcessCommandLine has_all (
  @"\AppData\Local\", "node.exe", ".js")
| project Timestamp, DeviceId, DeviceName, ActionType,
  FileName, FolderPath, ProcessCommandLine,
  ProcessVersionInfoOriginalFileName, SHA1,
  AccountDomain, AccountName, AccountUpn,
  InitiatingProcessFileName, InitiatingProcessFolderPath,
  InitiatingProcessCommandLine, InitiatingProcessSHA1,
  InitiatingProcessAccountName,
  InitiatingProcessIntegrityLevel,
  InitiatingProcessTokenElevation, ReportId
| order by Timestamp desc
```

THRESHOLD	WINDOW	JOIN	KEY	STATUS
None	Analyst-selected	None	Parent-child event	Untested



TRIAGE & INVESTIGATION

Turn the process event into attributable campaign evidence.

WORKFLOW

1

Validate lineage

Confirm exact child, parent, command lines, path, user and timestamps.

2

Verify Node.js

Inspect original filename, product metadata, SHA1, signer and source package.

3

Collect wrapper

Acquire the initiating JScript/VBS and any nonstandard-extension or encrypted files.

4

Trace delivery

Review MSI installation, PowerShell download, remote-support session and Teams evidence.

5

Scope follow-on

Pivot to EdgeUpdate persistence, screen capture, HTTPS polling, rundll32 and WinRM.

Escalate

Unmanaged portable runtime, suspicious wrapper, matching MSI, remote support, persistence or follow-on operator activity.

Benign context

Approved Electron/Node package, known wrapper, managed deployment, expected signer and change record.

Inconclusive

Historical event with missing wrapper, package provenance, file content or user context.

Response boundary

Do not attribute or contain solely from the KQL match. Corroborate the wrapper, runtime provenance and surrounding remote-support or MSI evidence.



FALSE POSITIVES & VALIDATION

Promotion gates for operational deployment.

QUALITY CONTROL

SCENARIO	OVERLAP	DISPOSITION
Electron or packaged Node application	M	Verify package, signer and install path
Developer automation	M	Verify owner, repository and wrapper
Endpoint-management deployment	M	Verify tool, ticket and distribution source
Unknown WScript wrapper and portable runtime	H	Collect artifacts and scope immediately

Validation steps

1. Confirm full child and parent command-line collection.
2. Run a benign WScript-to-portable-Node test under LocalAppData.
3. Measure legitimate hits and identify package owners.
4. Validate renamed Node.js visibility through version metadata.

Decision criteria

Success: controlled chain is visible and real hits are separable by package and wrapper provenance.

Rejection: legitimate packaging creates inseparable overlap.

Failure: command lines or parent identity are unavailable.

Tuning

Allowlist only verified packages, signer-plus-path combinations, managed deployment tools, repositories or device roles after evidence. Do not suppress Node.js or WScript globally.



CONCLUSION & REFERENCES

Coverage statement, cross-platform limits and document control.

FINAL

CONCLUSION

A source-backed execution hunt, not a generic Node.js alert.

The parent-child and LocalAppData chain is directly observed and Defender fields are documented. Legitimate Node/Electron packaging and execution drift block production classification until local validation.

Cross-SIEM decision

Splunk: no reliable SPL without a verified endpoint source, index, sourcetype and exact child, parent, command-line and version-metadata fields.

Chronicle: no reliable YARA-L without a verified endpoint parser and exact UDM mapping for created process, parent process, command line and file version metadata.

Deferred ideas

Generic Node.js alerts, Teams-to-endpoint correlation, persistence correlation, C2 domains, file hashes, entropy rules and WinRM aggregation.

References

1. Microsoft Security Research, 2 Sep 2026 - Impersonating IT support: how threat actors turn a remote session into enterprise-wide access. [microsoft\[.\]com/en-us/security/blog/2026/09/02/impersonating-it-support-threat-actors-turn-remote-session-into-enterprise-wide-access/](https://microsoft.com/en-us/security/blog/2026/09/02/impersonating-it-support-threat-actors-turn-remote-session-into-enterprise-wide-access/)
2. Microsoft Learn, updated 7 Aug 2026 - DeviceProcessEvents table. [learn\[.\]microsoft\[.\]com/en-us/defender-xdr/advanced-hunting-deviceprocessevents-table](https://learn.microsoft.com/en-us/defender-xdr/advanced-hunting-deviceprocessevents-table)
3. MITRE ATT&CK - T1059.007 and T1036. [attack\[.\]mitre\[.\]org](https://attack.mitre.org)

Document control

English dossier. No customer data. References defanged. HTML and rendering assets remain private and are excluded from publication.